

04 Excessive Data Exposure

Excessive data exposure is a vulnerability that affects APIs when a server provides more information than the user or application needs.

Rather than selecting individual fields, developers usually send complete data objects and assume that the client interface will show only the relevant information.

Yet attackers can intercept or query these responses directly to discover sensitive details that aren't visible, such as personal information, account data, or internal system values.

Filter data on the server side, establish strict response models, regularly review API outputs, and treat every returned field as potentially visible to anyone.